

2026-08-18

Redmark 弱點掃描報告

Vulnerability Scan Report

掃描目標

<https://example.com>

開始掃描時間

2026-08-18 11:05:46(UTC+8)

結束掃描時間

2026-08-18 11:07:58(UTC+8)

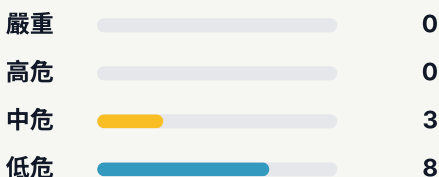
11

本次發現弱點數

整體風險概況 <https://example.com>

11

本次發現弱點數



掃描結果總結

本次掃描共發現11項弱點，其中3項中危、8項低危，整體風險為中危，應優先強化內容防護與資訊揭露相關安全機制。

主要風險為缺少內容防護標頭（CSP、點擊劫持防護、SRI integrity屬性）及Cookie、傳輸安全等機制缺失，X-Powered-By標頭與錯誤訊息可能揭露系統資訊，重新導向回應內容過大亦可能造成敏感資訊外洩。優先補齊CSP、點擊劫持防護等HTTP標頭並為外部資源設定integrity屬性，其次強化Cookie屬性、HSTS與傳輸安全設定，並移除不必要資訊揭露與過大重新導向內容，修補後應驗證修補結果。

修復路線建議

01

補齊內容防護標頭

設定CSP與點擊劫持防護相關HTTP標頭或frame-ancestors，並為外部script及link標籤設定integrity屬性，驗證資源完整性

02

強化Cookie與傳輸安全

為Cookie設定HttpOnly與SameSite屬性，並套用Strict-Transport-Security與nosniff標頭，降低劫持與竊取風險

03

減少資訊揭露暴露

移除X-Powered-By標頭、自訂錯誤頁面並精簡重新導向回應內容，避免可能揭露系統或敏感資訊

04

驗證修補與基線強化

完成修補後執行複測以驗證修補結果，並建立安全標頭與Cookie設定基線，持續監控回應狀態

弱點列表

<https://example.com>

弱點名稱	風險等級	首次發現時間
未設定 Content-Security-Policy (CSP) 標頭	● 中危	2026-08-18 11:07:58
缺少點擊劫持防護 HTTP 標頭	● 中危	2026-08-18 11:07:58
缺少子資源完整性 SRI 屬性	● 中危	2026-08-18 11:07:58
重新導向回應內容過大潛在敏感資訊外洩	● 低危	2026-08-18 11:07:58
Cookie 缺少 HttpOnly 屬性	● 低危	2026-08-18 11:07:58
Cookie 未設定 SameSite 屬性	● 低危	2026-08-18 11:07:58
X-Powered-By HTTP 回應標頭資訊洩漏	● 低危	2026-08-18 11:07:58
未設定 Strict-Transport-Security 標頭	● 低危	2026-08-18 11:07:58
缺少 X-Content-Type-Options 標頭	● 低危	2026-08-18 11:07:58
Unix 時間戳記資訊揭露	● 低危	2026-08-18 11:07:58
應用程式錯誤資訊揭露	● 低危	2026-08-18 11:07:58

未設定 Content-Security-Policy (CSP) 標頭

01

風險等級

● 中危

OWASP 分類

A02:2025 安全設定錯誤

弱點實例數量

5

首次發現時間

2026-08-18 11:07:58

上次發現時間

2026-08-18 11:07:58

弱點說明

回應未設定 Content-Security-Policy 標頭，瀏覽器無法依網站宣告的內容來源限制載入，降低對 XSS 與資料注入的防護能力。

修復說明

- 01 確認受影響網站回應範圍，盤點所有應設定 CSP 標頭的頁面與端點。
- 02 在提供回應的適用元件設定 Content-Security-Policy 標頭。
- 03 依網站實際需求宣告瀏覽器可載入的核准內容來源與資源類型。

修復驗證

- ☐ 檢查受影響回應已包含 Content-Security-Policy 標頭及核准來源設定。
- ☐ 重新執行弱點掃描，確認不再檢出 CSP 標頭未設定問題。

修復路徑



先確認未設定 CSP 標頭的受影響回應，再於適用元件設定標頭與核准內容來源，最後透過回應檢查及重掃確認不再檢出問題。

弱點實例列表 (5/5)

弱點實例	請求方法
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET

缺少點擊劫持防護 HTTP 標頭

02

風險等級

● 中危

OWASP 分類

A02:2025 安全設定錯誤

弱點實例數量

5

首次發現時間

2026-08-18 11:07:58

上次發現時間

2026-08-18 11:07:58

弱點說明

回應未提供點擊劫持防護，應設定 Content-Security-Policy 的 frame-ancestors 指令或 X-Frame-Options HTTP 標頭。

修復說明

- 01 盤點網站或應用程式所回傳的全部網頁回應與處理範圍項目。
- 02 於所有網頁回應設定 Content-Security-Policy 的 frame-ancestors 指令。
- 03 依頁面嵌入需求設定適當的 frame-ancestors 存取來源。
- 04 無法使用 CSP 時，於所有網頁回應設定 X-Frame-Options 標頭。

修復驗證

- ☐ 檢查各網頁回應均含 frame-ancestors 或 X-Frame-Options 標頭。
- ☐ 確認 frame-ancestors 或 X-Frame-Options 設定符合頁面嵌入需求。
- ☐ 重新執行弱點掃描，確認不再檢出缺少點擊劫持防護標頭。

修復路徑



先確認所有需納入處理的網頁回應，再依嵌入需求設定 CSP frame-ancestors 或 X-Frame-Options，最後透過回應檢查與重新掃描確認防護標頭已生效。

弱點實例列表 (5/5)

弱點實例	請求方法
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET

缺少子資源完整性 SRI 屬性

03

風險等級

● 中危

OWASP 分類

A02:2025 安全設定錯誤

弱點實例數量

5

首次發現時間

2026-08-18 11:07:58

上次發現時間

2026-08-18 11:07:58

弱點說明

由外部伺服器提供的 script 或 link 標籤缺少 integrity 屬性，外部資源遭竄改時可能載入惡意內容。

修復說明

01 盤點缺少 integrity 屬性的外部 script 與 link 標籤。

02 為每個適用標籤提供有效的 integrity 屬性設定。

03 確認 integrity 值與所引用資源內容保持一致。

修復驗證

- ☐ 檢查外部標籤，確認已設定有效 integrity 屬性。
- ☐ 確認各 integrity 值與引用資源內容相符。
- ☐ 重新執行弱點掃描，確認不再檢出此項弱點。

修復路徑



先確認受影響的外部資源與標籤，再補上有效的 integrity 屬性並確認其值正確，最後透過重新掃描確認不再檢出此弱點。

弱點實例列表 (5/5)

弱點實例	請求方法
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET

重新導向回應內容過大潛在敏感資訊外洩

04

風險等級
● 低危

OWASP 分類
A06:2025 不安全設計

弱點實例數量
9

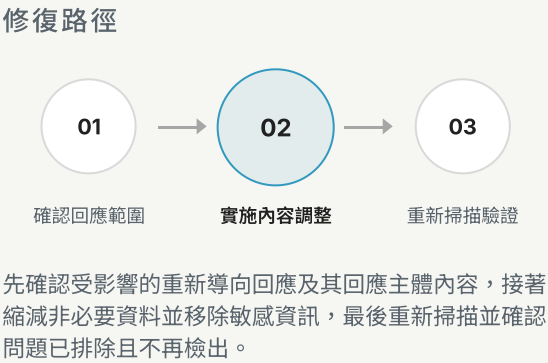
首次發現時間
2026-08-18 11:07:58

上次發現時間
2026-08-18 11:07:58

弱點說明
伺服器回傳重新導向時同時包含較大回應內容，可能含有敏感詳細資料或個人識別資訊，造成資訊外洩風險。

- 修復說明**
- 01 檢視已偵測的重新導向回應，確認是否含有非必要的回應主體內容。
 - 02 調整重新導向回應，使其僅保留幾乎不含內容的必要回應。
 - 03 確認重新導向回應主體不會揭露任何敏感資訊或個人識別資訊。

- 修復驗證**
- ☐ 檢查重新導向回應主體，確認其內容已縮減至幾乎不含資料。
 - ☐ 檢查重新導向回應主體，確認未揭露敏感資訊或個人識別資訊。
 - ☐ 重新執行弱點掃描，確認不再檢出此重新導向回應內容過大問題。



弱點實例列表 (9/9)

弱點實例	請求方法
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET

弱點實例	請求方法
https://example.com	GET

Cookie 缺少 HttpOnly 屬性

05

風險等級

● 低危

OWASP 分類

A02:2025 安全設定錯誤

弱點實例數量

5

首次發現時間

2026-08-18 11:07:58

上次發現時間

2026-08-18 11:07:58

弱點說明

Cookie 未設定 HttpOnly 屬性，可被 JavaScript 存取。若頁面可執行惡意指令碼，Cookie 可能被傳送至其他網站；若為工作階段 Cookie，可能造成工作階段劫持。

修復說明

- 01 盤點受影響應用程式各回應中設定的全部 Cookie。
- 02 為不需由 JavaScript 存取的 Cookie 設定 HttpOnly 屬性。
- 03 檢視 Cookie 使用情況，確認不需要 JavaScript 存取。
- 04 依既有變更管理流程部署更新後的 Cookie 安全設定。

修復驗證

- ☐ 檢查應用程式回應，確認受影響 Cookie 包含 HttpOnly 屬性。
- ☐ 確認限制 JavaScript 存取 Cookie 後，必要功能仍可正常運作。
- ☐ 重新執行弱點掃描，確認系統不再檢出此弱點。

修復路徑



先盤點受影響的 Cookie 與其 JavaScript 存取需求，再為不需要存取者設定 HttpOnly 屬性，最後檢查回應並重新掃描，確認不再檢出此弱點。

弱點實例列表 (5/5)

弱點實例	請求方法
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET

Cookie 未設定 SameSite 屬性

06

風險等級

● 低危

OWASP 分類

A01:2025 存取控制失效

弱點實例數量

5

首次發現時間

2026-08-18 11:07:58

上次發現時間

2026-08-18 11:07:58

弱點說明

Cookie 未設定 SameSite 屬性，可能隨跨網站請求傳送；該屬性可降低 CSRF、跨網站指令碼載入及時序攻擊風險。

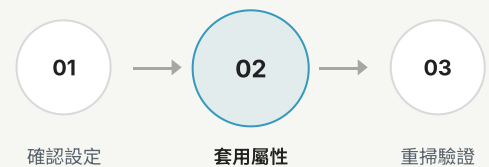
修復說明

- 01 盤點應用程式所設定且未含 SameSite 屬性的所有 Cookie。
- 02 在不影響既有功能前提下，將適用 Cookie 設定為 SameSite=Strict。
- 03 將其餘 Cookie 設定為 SameSite=Lax，確保所有 Cookie 均含該屬性。

修復驗證

- ☐ 檢查所有 Set-Cookie 標頭，確認皆含 SameSite=Strict 或 SameSite=Lax。
- ☐ 重新執行弱點掃描，確認不再檢出 Cookie without SameSite Attribute。

修復路徑



先確認所有未含 SameSite 屬性的 Cookie 範圍，再依適用情況設定 Strict 或 Lax，最後透過回應檢查與重掃確認不再檢出。

弱點實例列表 (5/5)

弱點實例	請求方法
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET

X-Powered-By HTTP 回應標頭資訊洩漏

07

風險等級

● 低危

OWASP 分類

A01:2025 存取控制失效

弱點實例數量

5

首次發現時間

2026-08-18 11:07:58

上次發現時間

2026-08-18 11:07:58

弱點說明

Web 或應用程式伺服器透過一個以上 X-Powered-By HTTP 回應標頭洩漏資訊，可能有助於識別相依元件及其潛在弱點。

修復說明

- 01 盤點網站、應用程式伺服器及反向代理的回應標頭設定來源
- 02 在各層設定中停用或移除 X-Powered-By 回應標頭輸出
- 03 部署後重新載入服務，避免預設值或中介層重新加入該標頭輸出設定

修復驗證

- ☐ 以瀏覽器開發工具或 curl 檢查各公開端點的回應標頭
- ☐ 確認正常與錯誤回應均未出現 X-Powered-By 標頭

修復路徑



先盤點各層標頭來源，再於伺服器、應用程式與代理停用輸出，重新載入後檢查公開端點的正常及錯誤回應是否皆未含 X-Powered-By 標頭。

弱點實例列表 (5/5)

弱點實例	請求方法
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET

未設定 Strict-Transport-Security 標頭

08

風險等級

● 低危

OWASP 分類

A02:2025 安全設定錯誤

弱點實例數量

5

首次發現時間

2026-08-18 11:07:58

上次發現時間

2026-08-18 11:07:58

弱點說明

未設定 Strict-Transport-Security 標頭，瀏覽器不會依 HSTS 政策僅透過 HTTPS 與網站連線。HSTS 由 RFC 6797 規範。

修復說明

- 01 確認提供受影響 HTTP 回應的所有相關服務元件範圍。
- 02 在相關服務元件設定強制套用 Strict-Transport-Security。
- 03 確認受影響回應均已套用 Strict-Transport-Security 標頭。

修復驗證

- ☐ 檢查受影響 HTTPS 回應是否包含 Strict-Transport-Security 標頭。
- ☐ 重新掃描受影響目標，確認不再檢出此弱點。

修復路徑



先確認提供受影響回應的元件範圍，再設定強制套用 HSTS，最後透過回應檢查與重新掃描確認標頭已生效且不再檢出弱點。

弱點實例列表 (5/5)

弱點實例	請求方法
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET

缺少 X-Content-Type-Options 標頭

09

風險等級

● 低危

OWASP 分類

A02:2025 安全設定錯誤

弱點實例數量

5

首次發現時間

2026-08-18 11:07:58

上次發現時間

2026-08-18 11:07:58

弱點說明

未將 X-Content-Type-Options 設為 nosniff，舊版 IE 與 Chrome 可能對回應本文進行 MIME 嗅探，並以不同於宣告的內容類型解譯及顯示。

修復說明

- 01 盤點所有網頁回應及其應宣告的 Content-Type 內容類型。
- 02 設定各網頁回應的 Content-Type 標頭，使其符合實際內容類型。
- 03 於所有網頁回應設定 X-Content-Type-Options: nosniff 標頭。

修復驗證

- ☐ 檢查各網頁回應的 Content-Type 標頭是否符合實際內容類型。
- ☐ 確認所有網頁回應均含 X-Content-Type-Options: nosniff 標頭。
- ☐ 重新執行弱點掃描，確認不再檢出此標頭缺失。

修復路徑



先盤點受影響網頁及其內容類型，再修正 Content-Type 並設定 nosniff 標頭，最後以回應檢查與弱點掃描確認缺失不再被檢出。

弱點實例列表 (5/5)

弱點實例	請求方法
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET
https://example.com	GET

Unix 時間戳記資訊揭露

10

風險等級

● 低危

OWASP 分類

A01:2025 存取控制失效

弱點實例數量

2

首次發現時間

2026-08-18 11:07:58

上次發現時間

2026-08-18 11:07:58

弱點說明

應用程式或 Web 伺服器揭露 Unix 時間戳記；若資料具敏感性或可彙整，可能暴露可利用模式。

修復說明

- 01 人工盤點各揭露端點的時間戳記內容，確認是否含有敏感業務或系統資訊。
- 02 評估跨頁面或跨時段彙整時間戳記後，是否可能推導可利用的行為模式。
- 03 於相關回應與頁面移除不必要時間戳記，並限制敏感資料僅供授權使用者存取。

修復驗證

- ☐ 確認揭露的時間戳記不具敏感性，亦不會形成可利用模式。
- ☐ 重新執行弱點掃描並檢查相關端點，確認系統不再回報此項弱點。

弱點實例列表 (2/2)

弱點實例	請求方法
https://example.com	GET
https://example.com	GET

修復路徑



先盤點各端點揭露的時間戳記及其敏感性，評估彙整後能否推導可利用模式；再移除非必要資料或限制授權存取，最後重新掃描相關端點並確認不再檢出。

應用程式錯誤資訊揭露

11

風險等級

● 低危

OWASP 分類

A02:2025 安全設定錯誤

弱點實例數量

1

首次發現時間

2026-08-18 11:07:58

上次發現時間

2026-08-18 11:07:58

弱點說明

頁面含有錯誤或警告訊息，可能揭露未處理例外所涉檔案位置等敏感資訊，並可被用於進一步攻擊網站。若訊息位於文件頁面，可能為誤報。

修復說明

01 檢視該頁面原始碼，找出造成未處理錯誤輸出的程式與觸發條件。

02 實作自訂錯誤頁面，避免向使用者揭露錯誤詳細資訊與內部路徑。

03 向瀏覽器提供唯一錯誤識別碼，並僅於伺服器端記錄詳細資訊。

修復驗證

- ☐ 檢查錯誤回應是否使用自訂頁面且未揭露詳細資訊。
- ☐ 確認回應含唯一錯誤識別碼，詳細資訊僅記錄於伺服器端。
- ☐ 重新執行弱點掃描，確認不再檢出此項弱點。

修復路徑



確認頁面揭露的錯誤資訊後，以自訂錯誤頁面和伺服器端記錄取代使用者可見的詳細輸出，並提供唯一錯誤識別碼，最後重新掃描確認不再檢出。

弱點實例列表 (1/1)

弱點實例	請求方法
https://example.com	GET